

Information Security Management System (ISMS) Policy

Office of the CISO | Version 5.1 | ISO 27001:2022 aligned

INTERNAL — All Employees

1. ISMS Scope, Context, and Statement of Applicability

The TechNova Information Security Management System (ISMS) is implemented in alignment with ISO/IEC 27001:2022 and is the formal control framework supporting the company's pursuit of SOC 2 Type II and ISO 27001 certification, both required as IPO-readiness milestones to be completed by December 2026.

Scope: the ISMS covers all information processing systems, personnel, and physical sites involved in the operation of the Nova Platform, including: production AWS and GCP infrastructure (covered services: API gateway, application services in Kubernetes, PostgreSQL transactional layer, TimescaleDB telemetry, Elasticsearch search and log analytics, AI/ML EKS cluster); corporate IT systems supporting Engineering, SRE, Customer Success, Finance, HR, and Legal; the Bangalore primary office; and any third-party processor with access to customer data.

The Statement of Applicability (SoA) maintained on Confluence documents which of the 93 Annex A controls in ISO 27001:2022 are applicable, which are excluded with justification, and the implementation status of each. As of March 2026, 89 controls are applicable; 4 are documented as excluded (controls relating to specialised hardware development that TechNova does not perform); 70% of applicable controls are at a "fully implemented" maturity level; 25% are at "partially implemented"; 5% are documented as "planned" with target completion before December 2026.

2. Information Asset Classification

TechNova classifies information assets into four sensitivity categories. All employees are trained on classification at onboarding and annually thereafter.

Class 1 - Public: information that is intentionally published and freely shareable. Examples: marketing collateral, public website content, published case studies. No specific handling controls.

Class 2 - Internal: information shared within TechNova and approved partners under NDA. Examples: org charts, internal documentation, non-customer-specific analytics. Default classification for new internal documents.

Class 3 - Confidential: information whose unauthorised disclosure would harm TechNova or its customers. Examples: customer lists, deal pipeline, source code, internal financial data, strategic plans. Encryption-at-rest required; access logged.

Class 4 - Restricted: information whose unauthorised disclosure could materially harm TechNova, customers, or third parties. Examples: customer personal data, customer-managed encryption keys, M&A; targets, board-level financials, security incident details prior to public disclosure, all DRHP working materials. Class-4 data requires customer-managed-key encryption where applicable, access on a strict need-to-know basis logged with reason, and any access for non-routine purposes requires CISO approval.

Customer data inherits the Class-4 classification unless the customer's MSA explicitly permits a lower classification (none currently do).

3. Access Control and Identity Management

Identity and access management is built on the principles of least privilege, separation of duties, and zero standing access for production systems.

All employee access to production systems is mediated through an identity-aware proxy (SSO via Okta) with mandatory hardware second factor (YubiKey or equivalent) for engineering staff. Standing privileged access to production has been eliminated as of January 2026 as part of the Zero Trust acceleration following INC-2025-0847; engineers request just-in-time access for up to 4 hours via a workflow that requires manager approval and is fully logged.

Customer data access by employees: Customer Success and Support staff have read-only access to customer-tenant data only when an active support ticket from that customer exists; access is automatically revoked 24 hours after ticket closure. Engineering staff do not have default access to production customer data; when an incident requires it, access is granted under break-glass procedure with CISO notification within 2 hours.

Vendor access: each vendor with access to TechNova systems has a named TechNova owner (the owner_department_id in the vendors table). Vendor access is reviewed quarterly by the owning department head. Suspended vendors (per the risk_status taxonomy) have access automatically disabled until risk-status is restored.

4. Risk Management Methodology

TechNova's information security risk management follows the ISO 27005 framework adapted to the SaaS context.

Risk identification is performed quarterly by the CISO's office in collaboration with the SRE, Engineering, and Product Security teams. Identified risks are entered into the Risk Register on Confluence. The Risk Register currently contains 47 active risks as of March 2026.

Risk assessment uses a 5x5 likelihood-impact matrix. Likelihood (1-5): Rare, Unlikely, Possible, Likely, Almost Certain. Impact (1-5): Insignificant, Minor, Moderate, Major, Catastrophic. Inherent risk score = likelihood x impact (1-25). Residual risk score is calculated after considering existing controls.

Risk treatment options: Accept (residual ≤ 6 with sign-off from the relevant department head), Mitigate (apply additional controls to reduce score), Transfer (cyber insurance currently provides INR

50 crore coverage for residual operational risk via the ICICI Lombard policy; the annual premium is INR 28 lakhs), or Avoid (discontinue the activity that creates the risk).

The current Risk Register top-5 by residual score: (i) AI infrastructure single-cluster concentration; (ii) data localisation non-compliance in Vietnam and Indonesia; (iii) Customer Revenue Officer single-point-of-failure; (iv) Capital expenditure variance in Engineering cloud spend; (v) Repeat security finding likelihood post INC-2025-0847.

5. Incident Response Integration

The ISMS interlocks with the Security Incident Response Plan to ensure that detection, response, and post-incident learning feed back into control improvements.

Detection is multi-source: SIEM (Splunk Cloud) ingests logs from AWS CloudTrail, GCP Audit Logs, Okta, application logs, Elasticsearch query logs, and network security monitors. Detection rules are tuned monthly. The mean time to detect (MTTD) for SEV-1 and SEV-2 incidents is targeted at under 30 minutes; FY2025-26 actual was 22 minutes for SEV-1 and 38 minutes for SEV-2.

Response: incident classification follows the SEV-1/2/3/4 taxonomy from the OnCall Runbook. SEV-1 incidents (complete platform outage or all-customer data loss) require 5-minute response time. SEV-2 incidents (major degradation affecting more than 20 percent of customers) require 15-minute response. INC-2025-0847 was a SEV-2 affecting 847 customer accounts; response and CERT-In notification within 6 hours met regulatory expectations.

Post-incident: every SEV-1 and SEV-2 generates a Root Cause Analysis (RCA) within 5 business days, signed off by the CISO and CTO. The RCA produces a control-improvement set that is added to the ISMS work-stream backlog and tracked to closure in the Audit Findings table.

6. Internal Audit and Continual Improvement

The ISMS is subject to an Internal Audit (IA) function reporting to the Audit Committee Chair (Dr. Vikram Reddy) with a dotted line to the CFO for operational matters. The IA Charter specifies independence from operational management of areas being audited.

The Internal Audit Plan FY2025-26 covers four domains in rotation: Engineering and Product (Q1), Finance and Procurement (Q2), HR and Compliance (Q3), and IT Operations and Security (Q4). The plan is approved annually by the Audit Committee. Critical or High findings from internal audit must be remediated within the timelines specified in the Audit Findings register; the IPO Committee tracks any finding flagged as ipo_blocker.

Management Review of the ISMS occurs semi-annually. The agenda includes: results of internal audits, results of external audits (SOC 2, ISO 27001, statutory), results of risk assessment, status of preventive and corrective actions, status of objectives, and recommendations for improvement. The minutes of Management Review are board-visible.

Continual improvement: the ISMS maintains an Improvement Backlog with 38 active items as of March 2026. Items range from "harden Okta MFA enrollment" (in progress) to "complete Vendor Risk

Management automation" (planned for Q3 FY2026-27). Closed items contribute to the move toward "fully implemented" maturity on the Statement of Applicability.

Copyright 2025-2026 TechNova Inc. All rights reserved.